

Kryptosystémy

Co je kryptosystém

- **kryptosystém** = ucelený soubor algoritmů, pravidel a klíčů pro zabezpečení komunikace
- neslouží jen k samotnému šifrování
- řeší také:
 - generování klíčů
 - výměnu klíčů
 - šifrování a dešifrování
 - ověření identity
 - kontrolu integrity dat
 - digitální podpisy
 - certifikáty

Příklad:

- komunikace mezi prohlížečem a internetovým bankovníctvím
- zpráva v šifrované komunikační aplikaci
- elektronicky podepsaný dokument
- HTTPS spojení

Kryptografie

Co je kryptografie

- **kryptografie** = obor zabývající se zabezpečením informací
- používá matematické metody pro ochranu dat
- cílem je, aby data byla bezpečně přenášena, ukládána a ověřována

Kryptografie řeší hlavně:

- důvěrnost
- integritu
- autenticitu
- nepopiratelnost

Důvěrnost

- data si přečte jen oprávněná osoba
- typicky se zajišťuje šifrováním

Příklad:

- zprávu si přečte jen příjemce se správným klíčem

Integrita

- data nebyla změněna
- příjemce může ověřit, že zpráva cestou nebyla upravena

Příklad:

- ověření hashe staženého souboru

Autenticita

- ověření identity odesílatele nebo serveru
- příjemce ví, s kým komunikuje

Příklad:

- prohlížeč ověří, že komunikuje opravdu s bankou

Nepopiratelnost

- autor nemůže jednoduše popřít, že zprávu nebo dokument podepsal
- souvisí s digitálním podpisem

Základní části kryptosystému

Otevřený text

- původní čitelná zpráva
- anglicky **plaintext**

Příklad:

Zaplatit fakturu

Šifrový text

- zašifrovaná podoba zprávy
- anglicky **ciphertext**
- bez klíče má být nečitelná

Šifrovací algoritmus

- postup, kterým se otevřený text převádí na šifrový text
- algoritmus může být veřejně známý
- bezpečnost má stát hlavně na tajnosti klíče

Dešifrovací algoritmus

- postup, kterým se šifrový text převádí zpět na otevřený text

Klíč

- hodnota používaná při šifrování nebo dešifrování
- bez správného klíče nemá být možné zprávu přečíst

Symetrické šifrování

- používá jeden společný tajný klíč
- stejný klíč se používá pro šifrování i dešifrování
- je rychlé
- používá se pro šifrování většího množství dat

Princip:

```
zpráva + tajný klíč → šifrový text  
šifrový text + stejný tajný klíč → zpráva
```

Příklady algoritmů:

- AES
- ChaCha20

Výhody:

- rychlé
- efektivní
- vhodné pro velká data

Nevýhody:

- obě strany musí znát stejný tajný klíč
- problém je bezpečné předání klíče
- pokud klíč unikne, útočník může data číst

Asymetrické šifrování

- používá dvojici klíčů:
 - veřejný klíč
 - soukromý klíč
- veřejný klíč může znát kdokoli
- soukromý klíč musí zůstat tajný

Princip šifrování:

odesílatel zašifruje zprávu veřejným klíčem příjemce
příjemce ji dešifruje svým soukromým klíčem

Příklady algoritmů:

- RSA
- ECC

Výhody:

- není nutné předem sdílet tajný klíč
- vhodné pro výměnu klíčů
- umožňuje digitální podpisy

Nevýhody:

- pomalejší než symetrické šifrování
- nehodí se pro šifrování velkého množství dat

Hashování

Co je hashování

- **hashování** = výpočet digitálního otisku dat
- vstupem mohou být libovolná data
- výstupem je krátký řetězec pevné délky
- výsledku se říká:
 - hash
 - digitální otisk
 - fingerprint
 - message digest

Hashování není šifrování, protože se běžně nedá vrátit zpět.

Příklad:

data → hash

Digitální otisk

- **digitální otisk** = výsledek hashovací funkce
- slouží k ověření, že data nebyla změněna
- i malá změna vstupu vytvoří úplně jiný hash

Příklad:

```
Soubor A → hash 123ABC  
Soubor A po změně → hash 9F84DE
```

Vlastnosti hashovací funkce

Jednosměrnost

- z hashe nemá být možné získat původní data
- hash není určen k dešifrování

Pevná délka výstupu

- hash má stejnou délku bez ohledu na velikost vstupu

Příklad:

- krátké slovo i velký soubor vytvoří hash stejné délky

Lavinový efekt

- malá změna vstupu výrazně změní výsledný hash

Příklad:

```
heslo123 → úplně jiný hash než heslo124
```

Odolnost proti kolizím

- kolize znamená, že dvě různá data mají stejný hash
- dobrá hashovací funkce má mít kolize extrémně nepravděpodobné

Použití hashování

Kontrola integrity souboru

- autor zveřejní hash souboru
- uživatel si po stažení spočítá hash svého souboru
- pokud se hashe shodují, soubor pravděpodobně nebyl změněn

Příklad:

```
hash od autora = hash staženého souboru
```

Ukládání hesel

- hesla se nemají ukládat v čistém textu
- ukládá se hash hesla
- při přihlášení se zahashuje zadané heslo
- výsledek se porovná s uloženým hashem

Zjednodušeně:

zadané heslo → hash → porovnání s databází

Poznámka:

- v praxi se k heslu přidává ještě **salt**
- salt pomáhá chránit proti předpočítaným tabulkám hashů
- v praxi se pro hesla nepoužívá obyčejný SHA-256, ale speciální pomalé hashovací funkce jako bcrypt, scrypt nebo Argon2

Digitální podpis

- hash dokumentu se používá jako základ pro podpis
- nepodepisuje se celý dokument, ale jeho otisk

Příklady hashovacích funkcí:

- SHA-256
- SHA-3
- starší MD5 a SHA-1

Poznámka:

- MD5 a SHA-1 se dnes nepovažují za bezpečné pro kryptografické účely

Digitální podpis

Co je digitální podpis

- **digitální podpis** = kryptografický mechanismus pro ověření autora a integrity dat
- slouží k ověření:
 - kdo dokument podepsal
 - že dokument nebyl změněn
- neřeší primárně utajení obsahu
- využívá hashování a asymetrickou kryptografii

K čemu slouží digitální podpis

Autenticita

- ověřuje, kdo dokument nebo zprávu podepsal

Integrita

- ověřuje, že dokument nebyl po podepsání změněn

Nepopiratelnost

- autor nemůže snadno popřít, že dokument podepsal svým soukromým klíčem

Jak vzniká digitální podpis

Postup:

1. Vezme se dokument.
2. Z dokumentu se spočítá hash.
3. Hash se podepíše soukromým klíčem autora.
4. Výsledkem je digitální podpis.
5. Dokument se pošle spolu s podpisem.

Zjednodušeně:

dokument → hash → podpis soukromým klíčem → digitální podpis

Jak se digitální podpis ověřuje

Postup:

1. Příjemce dostane dokument a digitální podpis.
2. Z dokumentu si sám spočítá hash.
3. Pomocí veřejného klíče autora ověří podpis.
4. Získaný hash porovná s hashem dokumentu.
5. Pokud se hashe shodují, dokument nebyl změněn a podpis odpovídá autorovi.

Zjednodušeně:

dokument + podpis + veřejný klíč → ověření

Důležitá poznámka

- digitální podpis není totéž co šifrování zprávy
- podepsaný dokument může být stále čitelný
- podpis jen dokazuje původ a neměnnost dokumentu

Digitální certifikát

Co je digitální certifikát

- **digitální certifikát** = elektronický doklad identity
- spojuje veřejný klíč s konkrétní osobou, organizací nebo serverem
- je podepsaný certifikační autoritou

Certifikát typicky obsahuje:

- název vlastníka
- doménu nebo identitu
- veřejný klíč
- dobu platnosti
- vydavatele certifikátu
- digitální podpis certifikační autority

Certifikační autorita

- **certifikační autorita** = důvěryhodná organizace, která vydává certifikáty
- zkratka **CA**
- ověřuje, že veřejný klíč opravdu patří danému subjektu
- prohlížeče mají seznam důvěryhodných certifikačních autorit

Příklad:

- server tvrdí, že je banka
- certifikát potvrzuje, že veřejný klíč patří dané doméně
- prohlížeč ověří podpis certifikační autority

TLS/SSL

Co je SSL

- **SSL** = Secure Sockets Layer
- starší protokol pro zabezpečení komunikace
- dnes se považuje za zastaralý
- v praxi byl nahrazen protokolem TLS

Co je TLS

- **TLS** = Transport Layer Security
- moderní protokol pro zabezpečení komunikace na internetu
- zajišťuje bezpečný přenos dat mezi klientem a serverem
- používá se například v HTTPS

HTTPS

- **HTTPS** = HTTP přes TLS
- bezpečnější varianta HTTP
- používá šifrovanou komunikaci
- chrání data před odposlechem a úpravou

Příklad:

```
https://example.com
```

- písmeno **S** znamená secure

Co TLS zajišťuje

TLS zajišťuje hlavně:

Důvěrnost

- komunikace je šifrovaná
- útočník by neměl přecíst obsah komunikace

Integritu

- chrání před nepozorovanou změnou dat během přenosu

Autenticitu

- klient může ověřit identitu serveru pomocí certifikátu

TLS handshake

Co je TLS handshake

- **TLS handshake** = úvodní fáze navázání zabezpečeného spojení
- klient a server si během ní dohodnou parametry bezpečné komunikace
- ověří se identita serveru
- dohodne se společný symetrický klíč

Zjednodušený průběh TLS handshake

1. Klient kontaktuje server

- prohlížeč se připojí k serveru
- pošle informace o podporovaných verzích TLS a šifrovacích metodách

2. Server pošle certifikát

- server pošle svůj digitální certifikát
- certifikát obsahuje veřejný klíč serveru
- certifikát je podepsaný certifikační autoritou

3. Klient ověří certifikát

- kontroluje, jestli certifikát:
 - patří správné doméně
 - není prošlý
 - je podepsaný důvěryhodnou certifikační autoritou
 - nebyl zneplatněn

4. Dohoda klíče

- klient a server se dohodnou na společném symetrickém klíči
- může se použít například Diffie-Hellman
- tajný klíč se po síti přímo neposílá

5. Šifrovaná komunikace

- po handshake už komunikace probíhá symetrickým šifrováním
- je to rychlé a vhodné pro přenos dat

Zjednodušeně:

ověření serveru → dohoda klíče → šifrovaná komunikace

Proč TLS používá hybridní šifrování

- asymetrická kryptografie je vhodná pro ověření identity a dohodu klíče
- symetrická kryptografie je rychlá a vhodná pro samotný přenos dat
- TLS proto kombinuje obě metody

Princip:

asymetricky / Diffie-Hellmanem se dohodne klíč
symetricky se šifrují přenášená data

Rozdíl SSL a TLS

SSL	TLS
starší protokol	modernější protokol
dnes zastaralý	dnes používaný

SSL	TLS
méně bezpečný	bezpečnější
nahrazen TLS	používá se v HTTPS

Poznámka:

- v běžné řeči se někdy pořád říká „SSL certifikát“
- technicky se dnes používá hlavně TLS

Příklad použití TLS v praxi

Když otevřeme internetové bankovníctví:

1. Prohlížeč naváže spojení se serverem banky.
2. Server pošle certifikát.
3. Prohlížeč ověří, že certifikát patří bance.
4. Klient a server se dohodnou na symetrickém klíči.
5. Další komunikace je šifrovaná.
6. Útočník by neměl umět číst ani měnit přenášená data.

Shrnutí

Pojem	Význam
Kryptosystém	soubor pravidel a algoritmů pro zabezpečení komunikace
Kryptografie	obor zabývající se ochranou informací
Hash	digitální otisk dat
Digitální otisk	výsledek hashovací funkce
Digitální podpis	ověření autora a integrity dat
Certifikát	potvrzení vazby mezi identitou a veřejným klíčem
CA	certifikační autorita
SSL	starší zabezpečovací protokol
TLS	moderní zabezpečovací protokol
HTTPS	HTTP komunikace zabezpečená pomocí TLS